COMPLY 24

COMPLIANCE INTELLIGENCE · QUICKSCAN

Van wet naar aantoonbaar bewijs.

Voorbeeldrapport
DORA · ICT-third-party risk

Een risicogebaseerde gap-assessment van contracten, beleid en beheersmaatregelen, met herleidbaarheid tot artikel, lid en bron.

VOOR

Noordhaven Bank N.V. · fictieve casus

Rapportdatum 11 oktober 2026 · referentie C24-QS-EX-001 · doorlooptijd tien werkdagen

ILLUSTRATIEF VOORBEELD

Voorbeelddocument. Alle klantdocumenten, beoordelingen en bevindingen zijn fictief. Geen assurance-oordeel.

01 · EXECUTIVE VIEW

De kern in één oogopslag

EXECUTIVE CONCLUSIE

De basis is aanwezig.
De contractuele borging blijft achter.

Vooral onderuitbesteding, auditrechten, concentratiebeheersing en exit-afspraken vragen aantoonbare verbetering.

12	4	5	3
controls beoordeeld	GAP	DEELS	GEDEKT

Wat dit betekent voor het bestuur

- **Er is richting.** Beleid, leveranciersselectie en SLA-monitoring zijn deels aantoonbaar ingericht.
- **Er is blootstelling.** Vier normpunten missen een controleerbare vertaling naar contracten of processen.
- **Er ligt een uitvoerbaar pad.** De bevindingen zijn te koppelen aan eigenaars, bewijsstukken en een plan van 90 dagen.

ADVIES AAN MANAGEMENT

Stel binnen tien werkdagen een eigenaar per prioriteit vast en start contractuele herstelacties voor kritieke leveranciers.

02 · OPDRACHTKADER

Wat we hebben beoordeeld

KLANT EN PERIODE

Noordhaven Bank N.V. (fictief)
Voorbeeldperiode: tien werkdagen

REGELGEVEND KADER

DORA · Verordening (EU) 2022/2554
Focus: ICT-dienstverleners en contracten

In scope

- ✓ Eén thema: beheersing van ICT-derden die kritieke of belangrijke functies ondersteunen.
- ✓ Regelgeving op geselecteerde artikelniveaus: artikelen 28, 29 en 30 DORA.
- ✓ Drie fictieve interne documenten, twaalf toetsbare controls en vier prioritaire bevindingen.

Buiten scope

- ⚠ Geen technisch penetratieonderzoek of werkingstest.
- ⚠ Geen volledige juridische beoordeling van alle DORA RTS en ITS.
- ⚠ Geen formeel assurance-oordeel of garantie op naleving.

DE OPDRACHTVRAAG

Welke verplichtingen uit DORA zijn relevant voor dit gekozen thema, hoe zijn die vertaald naar interne controls, en wat bewijzen de aangeleverde documenten wel — en nog niet?

De rapportage is een gedateerde momentopname op basis van de documenten in de overeengekomen scope. Nieuwe wetgeving en bijgewerkte interne documenten vallen daarbuiten.

03 · DOCUMENTEN EN METHODE

Van bron naar oordeel

D01	**ICT Third-Party Risk Policy** Governance, risicobereidheid, beleid	v2.3 · 01 jul 2026
D02	**CloudServ EU – Master Agreement** Contract met SLA-bijlage, kritieke ICT-dienst	v4.1 · 12 mei 2026
D03	**ICT Vendor Register** Leveranciers, kritikaliteit, afhankelijkheden	Q3 2026 · 30 sep 2026

⚠ **Belangrijke waarborg:** een GAP betekent hier *niet aantoonbaar binnen de onderzochte bewijsset*. Het is geen vaststelling dat de organisatie de wet overtreedt.

De keten in zes stappen

01 **Wet** Bepaling en lid	02 **Verplichting** Norm uitgewerkt	03 **Control** Toetsbare eis
04 **Bewijs** Document en citaat	05 **Oordeel** GAP / DEELS / GEDEKT	06 **Actie** Eigenaar en termijn

Beoordelingsschaal

✓ GEDEKT	Eis aantoonbaar afgedekt in de beoordeelde documenten.
⚠ DEELS	Onderdeel aanwezig; essentiële uitwerking of bewijs ontbreekt.
⚠ GAP	Geen toereikende onderbouwing in de aangeleverde scope.

HUMAN-IN-THE-LOOP

Het platform ondersteunt bij identificatie, koppeling en conceptbevindingen. Een bevoegde reviewer beoordeelt de bron, bevestigt het oordeel en legt afwijkingen of beperkingen vast.

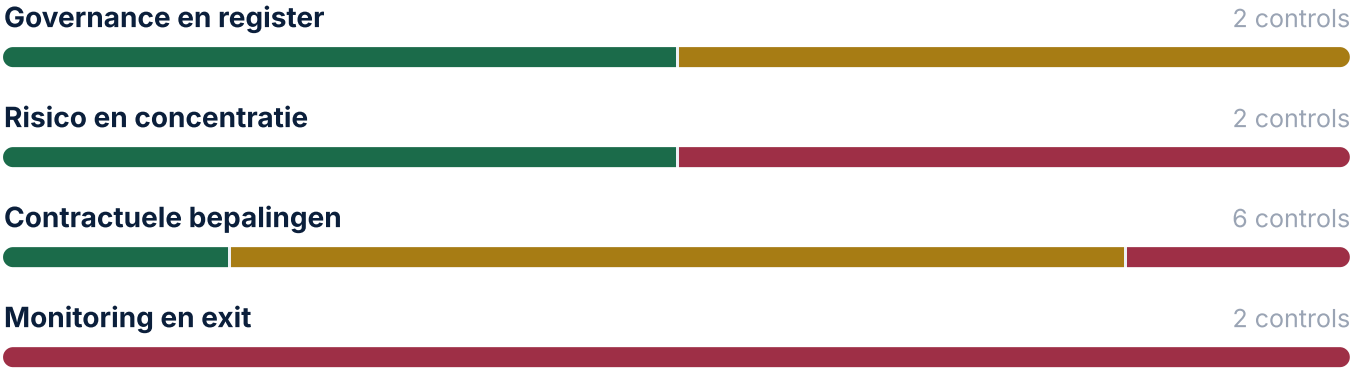
04 · RESULTAAT PER THEMA

Waar de instelling staat

25% 3 van de 12 controls zijn als GEDEKT beoordeeld; 5 DEELS en 4 GAP. Dit is een scope-indicator, geen uitspraak over de totale DORA-naleving.

3 GEDEKT **5** DEELS **4** GAP

Beoordelingen per domein



Lezing: prioriteiten volgen uit normrelevantie, impact op kritieke ICT-diensten en de kwaliteit van het beschikbare bewijs. Niet uit een generieke AI-score.

05 · CONTROLEREGISTER

Artikel, bewijs en status

ID	DORA	CONTROL OF EIS	BEWIJS	STATUS	PRIO
C01	28(1)	Verantwoordelijkheid voor ICT-derden	D01 §2	✓ GEDEKT	P3
C02	28(3)	Register van ICT-dienstverleners	D03 tab 1	⚠ DEELS	P2
C03	28(4)	Risicobeoordeling vóór contractering	D01 §4	✓ GEDEKT	P3
C04	29(1)	ICT-concentratierisico	D03 tab 2	⚠ GAP	P1
C05	30(2)(a)	Scope en voorwaarden onderuitbesteding	D02 §3.2	⚠ GAP	P1
C06	30(2)(b)	Locaties en wijzigingsmelding	D02 §8.1	⚠ DEELS	P2
C07	30(2)(c)	Data-integriteit en vertrouwelijkheid	D02 §5	⚠ DEELS	P2
C08	30(2)(d)	Toegang, herstel en teruggave van data	D02 §9	⚠ DEELS	P2
C09	30(3)(a)	SLA en meetbare prestatiecriteria	D02 bijl. A §2	✓ GEDEKT	P3
C10	30(3)(b)	Melding materiële ontwikkelingen	D02 §7	⚠ DEELS	P2
C11	30(3)(e)	Monitoring en auditrechten	D02 §10	⚠ GAP	P1
C12	30(3)(f)	Exit en overgangsperiode	D02 §4	⚠ GAP	P1

Legenda: P1 = hoge prioriteit; P2 = herstel plannen; P3 = beheren en blijven toetsen. De status betreft uitsluitend de aangeleverde fictieve documenten en kan na aanvullend bewijs wijzigen.

06 · BEVINDING F-01

Onderuitbesteding

RISICOPROFIEL
HOOG / P1

DORA art. 30(2)(a)

KERNBEOORDELING

De contractclausule staat inzet van onderaannemers breed toe, maar de voorwaarden voor onderuitbesteding van diensten die kritieke functies ondersteunen zijn onvoldoende bepaalbaar.

BRONCITAAT (FICTIEF)

> *"De leverancier kan onderaannemers inzetten indien dit noodzakelijk is voor een adequate uitvoering van de diensten." (D02 §3.2)*

WAAROM DIT RELEVANT IS

De norm vraagt expliciete duidelijkheid of onderuitbesteding is toegestaan en onder welke voorwaarden. Zonder toetsbare voorwaarden ontbreekt aantoonbare sturing op de keten.

AANBEVOLEN HERSTELACTIES

- ✓ Maak per kritieke dienst de toegestane onderuitbesteding en voorwaarden expliciet in de contractbijlage.
- ✓ Definieer een voorafgaand beoordelings- en notificatieproces voor relevante wijzigingen.
- ✓ Leg goedkeuring en herbeoordeling vast in het ICT-leveranciersregister.

AANBEVOLEN VERANTWOORDELIJKE

Legal en Procurement samen met de Third-Party Risk Owner · conceptaddendum binnen 30 dagen

07 · HERSTELAGENDA

Aanpak voor de eerste 90 dagen

0–15D

Besluit en eigenaarschap

P1-eigenaren benoemen; contracten en kritieke diensten prioriteren.

Management / Compliance

15–30D

Contractaddenda

Onderuitbestedings-, audit- en locatieclausules opstellen en reviewen.

Legal / Procurement

30–60D

Concentratiebeeld

Afhankelijkheden, vervangbaarheid en ketenrisico vastleggen.

Risk / Vendor Mgmt

30–75D

Exitplan en testontwerp

Overgangsperiode en testcriteria vastleggen per kritieke ICT-dienst.

IT / BCM / Security

60–90D

Hertoets en bewijs

Bevindingen met nieuwe documenten opnieuw beoordelen en afsluiten.

Compliance / Reviewer

Besluitpoort na dag 90: herbevestig de status op actuele documenten. Sluit alleen af op aantoonbaar bewijs, niet op voorgenomen acties.

08 · HERLEIDBAARHEID

Van wet naar bewijs, in één keten

01 NORM
DORA · artikel 30(2)(a)

02 VERPLICHTING
Onderuitbesteding alleen onder expliciete voorwaarden

03 CONTROL
C05 · Beschreven en beoordeelde onderuitbesteding

04 BRON
D02 §3.2 · contractversie 4.1

05 BEOORDELING
GAP · F-01 · reviewer bevestigd

06 ACTIE
Contractaddendum en registerupdate · P1

Waarom dit telt: als een bron wijzigt, blijft zichtbaar welke eerder bevestigde control, conclusie en actie daardoor opnieuw moeten worden bekeken.

Een afgerond resultaat

01
Rapport ontvangen
Normenkader, gap-register, managementsamenvatting en herleidbaarheid.

02
Verbeteren
Uw team voert de acties uit met bestaande tooling of op eigen wijze.

03
Optioneel doorgaan
Bij gebruik van Comply24 wordt het kader doorlopend bijgewerkt en herbeoordeeld.

Geraadpleegde publieke bronnen

Verordening (EU) 2022/2554 (DORA), art. 28–30
EUR-Lex · CELEX:32022R2554

DORA van toepassing per 17 januari 2025
De Nederlandsche Bank · dnb.nl

Registers of information onder DORA
European Banking Authority · eba.europa.eu